



Instituto Politécnico Nacional

Escuela Superior de Cómputo



Gobierno de IT | Governance IT

BIAs Tácticos

Equipo 3:

Camacho Zavala Ricardo

García García Aram Jesua

Rodríguez Martínez Erick Damián

7CV4

BIA's Tácticos

1. Introducción

El Análisis de Impacto al Negocio (BIA, por sus siglas en inglés) a nivel táctico constituye una herramienta fundamental para identificar, evaluar y priorizar la resiliencia de los procesos estratégicos que sostienen la continuidad de los servicios de TI. De conformidad con las directrices internacionales de la norma ISO 22301:2012 (Sistemas de Gestión de la Continuidad del Negocio), este análisis no se limita a la operación técnica del día a día, sino que se enfoca en los pilares tácticos que aseguran el cumplimiento de los objetivos institucionales, la protección de los activos y la mitigación de riesgos críticos.

Para el servicio de Transferencia de Archivos Cifrados (ID del Servicio: TAC-355415), el BIA táctico se vuelve indispensable debido a la naturaleza crítica de las funciones que integra: el cifrado de extremo a extremo utilizando el algoritmo ChaCha20-Poly1305, la gestión y gobernanza de llaves criptográficas (KMS) alineada a COBIT 2019, y la entrega de información bajo un modelo de Conocimiento Cero (Zero-Knowledge). Una interrupción prolongada en cualquiera de estos subprocesos clave no solo paralizaría el flujo seguro de datos institucionales entre emisores y receptores en la red local (LAN), sino que expondría a la organización a brechas de seguridad catastróficas, pérdida inaceptable de la integridad de los datos, incumplimientos regulatorios de privacidad y daños severos a la reputación y confianza del servicio.

2. Objetivo

El objetivo del presente documento es analizar y determinar el impacto táctico, operativo y económico que generaría una interrupción en los procesos de Cifrado y resguardo de activos (TAC_PROC_01), Gestión de permisos y llaves (TAC_PROC_02) y Descifrado y entrega (Zero-Knowledge) (TAC_PROC_03) dentro del ecosistema del servicio de Transferencia de Archivos Cifrados.

A través de este análisis, se busca identificar los recursos de infraestructura y personal críticos, cuantificar los tiempos límite de tolerancia mediante el establecimiento del Máximo Periodo de Interrupción Tolerable (MTPoD) y el Tiempo de Recuperación Objetivo (RTO), y definir el Objetivo Mínimo de Continuidad del Negocio (MBCO). Todo esto con el propósito de diseñar e implementar estrategias de mitigación y mecanismos de continuidad operacional eficaces que garanticen la inmutabilidad, confidencialidad y disponibilidad de los activos de información ante escenarios de contingencia tecnológica.

3. Procedimiento 1

3.1 Identificación del proceso

Proceso:	Cifrado y resguardo de activos
Grupo de Productos y Servicios relacionados:	Transferencia de Archivos Cifrados (ID: TAC-355415)
Responsable (Área/Función):	Especialista en Ciberseguridad / Desarrollo Backend
Nombre del responsable:	García García Aram Jesua
Fecha de llenado:	02 de junio de 2026

3.2 Tipo y nivel de impacto al negocio por la interrupción en el proceso

Nota: Requisito de ISO 22301:2012: 8.2.2.b) Valorar los impactos a través del tiempo por no ejecutar estas actividades.

No aplica (**N**) Bajo (**B**) Medio (**M**) Alto (**A**)

[illegible]

Pérdida de calidad	B	B	B	M	M	M	A	A	A	A	A
Pérdida de productividad	B	B	B	B	M	M	A	A	A	A	A
Pérdida de control	B	B	B	M	M	A	A	A	A	A	A
Daño a la salud y/o bienestar de personas	N	N	N	N	N	N	N	N	N	N	N
Daño medio-ambiental	N	N	N	N	N	N	N	N	N	N	N
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓

3.3 Máximo periodo de interrupción tolerable (MTPoD / MAO) para el proceso

(Tiempo que tomaría para que los impactos adversos, que pueden resultar de no proveer un producto/servicio o la no ejecución de una actividad, sean inaceptables)

Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Máximo periodo de interrupción tolerable (MTPoD / MAO)										
<5 Min.	<15 Min.	<30 Min.	<1 Hrs.	<2 Hrs.	<5 Hrs.	<12 Hrs.	<24 Hrs.	<48 Hrs.	<120 Hrs.	Tiempo específico
						X				

3.4 Identificar tiempo de recuperación objetivo (RTO) para el proceso

(Periodo de tiempo después de un incidente en el que se debe reanudar un producto o servicio, reanudar una actividad o recuperar un recurso)

Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Tiempo de recuperación objetivo (RTO)										
<5 Min.	<15 Min.	<30 Min.	<1 Hrs.	<2 Hrs.	<5 Hrs.	<12 Hrs.	<24 Hrs.	<48 Hrs.	<120 Hrs.	Tiempo específico
						X				

3.5 Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso

(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

El objetivo mínimo de continuidad es asegurar la persistencia y disponibilidad de la infraestructura local de almacenamiento de llaves y el aislamiento del Servidor de Datos. Ante una contingencia, el sistema debe garantizar que el resguardo y aislamiento de los volúmenes de datos previamente cifrados con ChaCha20-Poly1305 se mantenga inmutable, permitiendo de manera local el monitoreo manual de accesos de emergencia y la activación inmediata del almacenamiento de respaldo externo en la nube antes de que se cumpla el límite de 8 horas establecido en el SLA para la Administración de Servidores.

3.6 Identificar actividades que soportan la operación de este proceso

Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar actividades que soportan la provisión de productos y servicios.

Actividades que soportan el proceso	ID
Segmentación y lectura de archivos en fragmentos de memoria (80KB)	1.1
Generación de claves efímeras KEK (32 bytes) y vectores Nonce (96 bits)	1.2
Cifrado de datos en tránsito y reposo mediante ChaCha20-Poly1305	1.3
Encriptación asimétrica de la KEK con el estándar RSA-OAEP del servidor	1.4
Firmado digital y cálculo de integridad con funciones hash SHA-256 y HMAC	1.5
Escritura indexada de metadatos criptográficos en la base de datos SQL Server	1.6

3.7 Identificar opciones actuales de continuidad operacional

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Cifrado de datos	Uso de bibliotecas criptográficas locales (<i>pycryptodome / cryptography</i>) ejecutadas en estaciones locales de contingencia offline
2	Resguardo de secretos	Copias de seguridad locales automatizadas con marca de tiempo del par de claves RSA-4096 del servidor en directorios aislados.
3	Almacenamiento de archivos	Replicación manual programada de la base de datos "ApplicationDBContext" hacia dispositivos de almacenamiento redundante externo.
4	Monitoreo de integridad	Ejecución local de scripts alternos en Python para auditorías y verificación de tablas hash sin dependencia de la red centralizada.

3.8 Interdependencia con otros procesos y/o actividades

Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar dependencias y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.

Procesos / actividades de los que se **recibe** información.

ID	Proceso / actividad
1	Entrada de datos origen y solicitudes de resguardo por parte del Administrador/Dueño del servicio.

Procesos / actividades de los que se **envía** información.

ID	Proceso / actividad
1	Gestión de permisos y llaves (provee los metadatos y llaves cifradas legibles únicamente bajo validación de roles).
2	Descifrado y entrega (envía el bloque de datos íntegro empaquetado para su procesamiento Zero-Knowledge en el cliente receptor)

[illegible]

4.3 Máximo periodo de interrupción tolerable (MTPoD / MAO) para el proceso

(Tiempo que tomaría para que los impactos adversos, que pueden resultar de no proveer un producto/servicio o la no ejecución de una actividad, sean inaceptables)

Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Máximo periodo de interrupción tolerable (MTPoD / MAO)										
<5 Min.	<15 Min.	<30 Min.	<1 Hrs.	<2 Hrs.	<5 Hrs.	<12 Hrs.	<24 Hrs.	<48 Hrs.	<120 Hrs.	Tiempo específico
					X					

4.4 Identificar tiempo de recuperación objetivo (RTO) para el proceso

(Periodo de tiempo después de un incidente en el que se debe reanudar un producto o servicio, reanudar una actividad o recuperar un recurso)

Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Tiempo de recuperación objetivo (RTO)										
<5 Min.	<15 Min.	<30 Min.	<1 Hrs.	<2 Hrs.	<5 Hrs.	<12 Hrs.	<24 Hrs.	<48 Hrs.	<120 Hrs.	Tiempo específico
				X						

4.5 Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso

(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

El objetivo mínimo de continuidad es asegurar que el motor de validación de políticas de acceso y la administración de llaves maestras (KEK) se mantengan disponibles a través de un nodo secundario de contingencia. Ante una caída del backend web principal, el sistema debe permitir la verificación offline o distribuida de los tokens de identidad (JWT) y mantener la lectura de los permisos históricos asignados por el emisor en la base de datos distribuida, permitiendo la generación e intercambio seguro de paquetes de llaves para el receptor con una capacidad degradada pero segura, previniendo fallos de denegación de acceso injustificado.

4.6 Identificar actividades que soportan la operación de este proceso

Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar actividades que soportan la provisión de productos y servicios.

Actividades que soportan el proceso	ID
Recepción de solicitudes de acceso a archivos específicos por parte de los Usuarios Consumidores.	2.1
Consulta en base de datos para verificar la existencia de un permiso activo otorgado por el emisor.	2.2
Ejecución del servicio de mensajería síncrona/asíncrona para notificar al emisor sobre solicitudes pendientes de autorización.	2.3
Validación algorítmica de marcas de tiempo y fechas de expiración temporales del permiso del archivo.	2.4
Descodificación y verificación criptográfica de la firma del Token JWT para validar los roles de usuario asignados.	2.5
Cómputo y empaquetamiento seguro de las claves criptográficas destinadas al receptor autorizado.	2.6
Habilitación e invocación de la interfaz web dinámica para autorizar la descarga/visualización del contenido.	2.7

4.7 Identificar opciones actuales de continuidad operacional

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Validación de Roles (JWT)	Uso de llaves de respaldo locales para la verificación de firmas de tokens en servidores proxy alternos, previniendo caídas del proveedor de identidad centralizado.
2	Consulta de Permisos	Réplica de solo lectura en caché local de la tabla de control de acceso basada en SQL Server Express para autorizar accesos pre-aprobados durante interrupciones de red.
3	Notificaciones de Solicitud	Enrutamiento de alertas mediante un canal secundario basado en logs locales del sistema cuando el módulo principal de notificaciones web se encuentra fuera de servicio.
4	Generación de Paquetes KEK	Ejecución de scripts independientes en Python ejecutados del lado del servidor criptográfico aislado para procesar las llaves maestras (wrapping/unwrapping) manualmente.

4.8 Interdependencia con otros procesos y/o actividades

Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar dependencias y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.

Procesos / actividades de los que se **recibe** información.

ID	Proceso / actividad
1	Proceso 1 (TAC_PROC_01): Cifrado y resguardo de activos

Procesos / actividades a los que se **envía** información.

ID	Proceso / actividad
1	Proceso 3 (TAC_PROC_03): Descifrado y entrega (Zero-Knowledge)

[illegible]

[illegible]

5.5 Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso

(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

El objetivo de continuidad del negocio mínimo es garantizar que el receptor o usuario consumidor pueda efectuar la descarga de los activos digitales críticos incluso durante contingencias en la aplicación web, realizando el descifrado del paquete utilizando herramientas manuales o protocolos alternativos. Se debe mantener la integridad de la base de datos criptográfica, asegurando que el mecanismo de respaldo de llaves y el entorno de ejecución permitan la restauración funcional de la visualización para el receptor. El tiempo máximo de reanudación permitido antes de violar el SLA crítico y afectar irreversiblemente la disponibilidad de aplicaciones en el negocio es de 8 horas.

5.6 Identificar actividades que soportan la operación de este proceso

Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar actividades que soportan la provisión de productos y servicios.

Actividades que soportan el proceso	ID
Descarga de archivo cifrado iniciada por el receptor y envío por parte del servidor junto con KEK protegida por RSA	1.1
Autenticación de sesión del usuario para la obtención de la llave privada RSA	1.2
Descifrado asimétrico de la KEK (Key Encryption Key) en el entorno aislado del cliente	1.3
Verificación cruzada de integridad confirmando que el Hash y AuthTag coinciden usando HMAC-SHA256	1.4
Descifrado final utilizando ChaCha20 y despliegue del contenido en texto plano para el usuario	1.5

5.7 Identificar opciones actuales de continuidad operacional

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Entrega / Descarga de archivo	Compatibilidad y uso alternativo del protocolo SCP para transferencia básica en dispositivos
2	Verificación de firmas / Hash	Subservicio secundario que entrega logs analizados con Python y validación de firmas SHA-256 de forma manual
3	Respaldo de Base de Datos y Logs	Restauración y consulta local hacia el respaldo en SQLite o PostgreSQL mediante consultas directas
4	Recuperación de claves RSA en Servidor	Invocación manual automática a copias de seguridad de llaves RSA con marca de tiempo en el directorio
5	Autenticación temporal y roles	Análisis dinámico de excepciones y cruce de roles manejado administrativamente desde SQL Server Express

5.8 Interdependencia con otros procesos y/o actividades

Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar dependencias y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.

Procesos / actividades de los que se **recibe** información.

ID	Proceso / actividad
1	Proceso 1 (TAC_PROC_01): Cifrado y resguardo de activos
2	Proceso 2 (TAC_PROC_02): Gestión de permisos y llaves

Procesos / actividades a los que se **envía** información.

ID	Proceso / actividad
1	Usuario Consumidor (Visualización y consumo del contenido)